MISC入门

MISC，即安全杂项，是一个综合性很强的方向，涉及到隐写、流量分析、电子取证等等多方面的内容。

一、文件类

（一）文件类型识别

杂项题目很多都是有附件的，有时候给的文件不一定有后缀，或者后缀是错误的，这个时候需要我们去识别这些文件。

工具：Kali file命令、010 Editor或Winhex

1 file命令

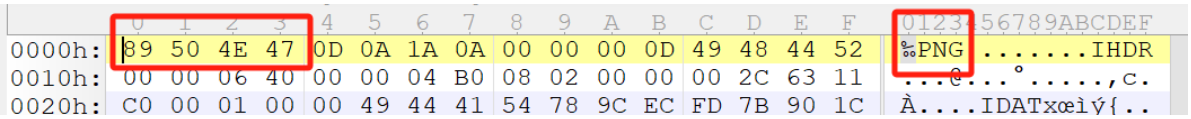
```
file [文件名]
```

2 010 Editor / Winhex

原理：为了便于计算机识别，文件通常会包含除文件内容本身以外的一些特征标识，这种标识通常放于文件开头，因此常用**文件头**指代。

文件头总结：https://blog.csdn.net/Ahuuua/article/details/109165473

文件类型	文件头	特征
JPEG (jpg)	FFD8FF	ÿØÿà
PNG (png)	89504E47	.PNG...
GIF (gif)	47494638	GIF89a
ZIP Archive (zip)	504B0304	PK..
TIFF (tif)	49492A00	
Windows Bitmap (bmp)	424D	BM
RAR Archive (rar)	52617221	Rar!...



例题：ctfshow - 菜狗杯 - 损坏的压缩包 https://ctf.show/challenges

图片文字提取：https://web.baimiaoapp.com/

（二）文件分离

1 binwalk

下载：

```
sudo apt-get install binwalk
```

用法：

```
binwalk [文件名]          分析文件
binwalk -e [文件名]       分离文件
```

例题：ctfshow - misc入门 - misc10

2 foremost

下载：

```
sudo apt-get install foremost
```

用法：

```
foremost [文件名]
```

例题：ctfshow - misc入门 - misc8

如果其中一个命令分离不出来就可以尝试使用另一个命令

二、图片隐写类

（一）图片信息查看

1 图片属性

备注中可能会出现提示或flag

作者	GWHT{6916067b-c8c1-31
拍摄日期	
程序名称	1b-bdd0-c689bec52e08}

2 exiftool

下载：

```
sudo apt-get install exiftool
```

用法：

```
exiftool [文件名]
```

例题：ctfshow - misc入门 - misc18

3 strings命令

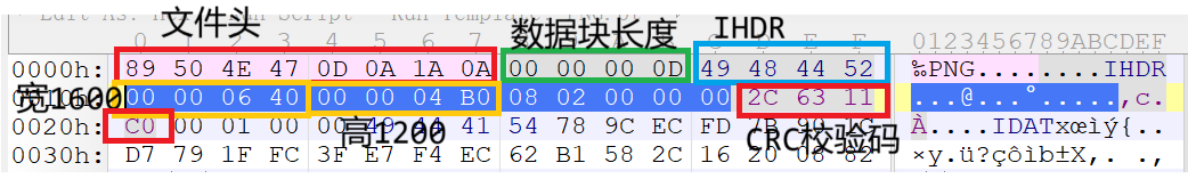
有时候flag或提示以字符串的形式藏在文件中，此时可以用strings命令在文件中查找可打印的字符串

```
strings [文件名]
```

也可以在010 Editor中使用 CTRL+F 搜索flag头尝试查找

例题：ctfshow - misc入门 -misc5

（二）png高/宽度



（1）文件头：8个字节`89 50 4E 47 0D 0A 1A 0A`

（2）头部数据块长度：4个字节`00 00 00 0D`，代表长度为13

（3）IHDR：4个字节`49 48 44 52`，代表后面的数据块为IHDR

（4）IHDR数据块：13个字节

前四个字节代表图片的宽`00 00 01 FF`

后面四个字节代表图片的高`00 00 01 FF`

再后面五个字节代表其他信息

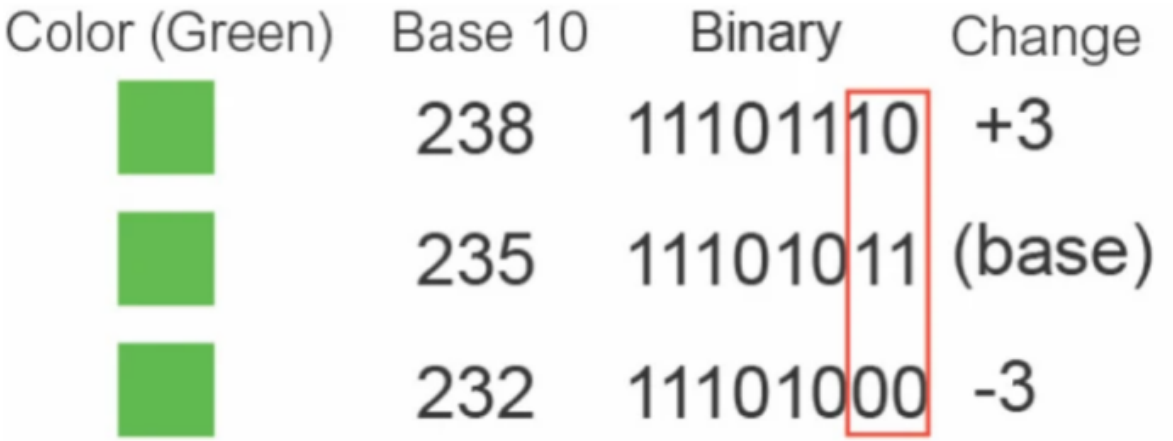
（5）剩余四字节为CRC校验码`59 F1 D4 BE`

手动校验CRC：http://www.ip33.com/crc.html，输入IHDR的17个字节

例题：ctfshow - misc入门 - misc25

（三）lsb隐写

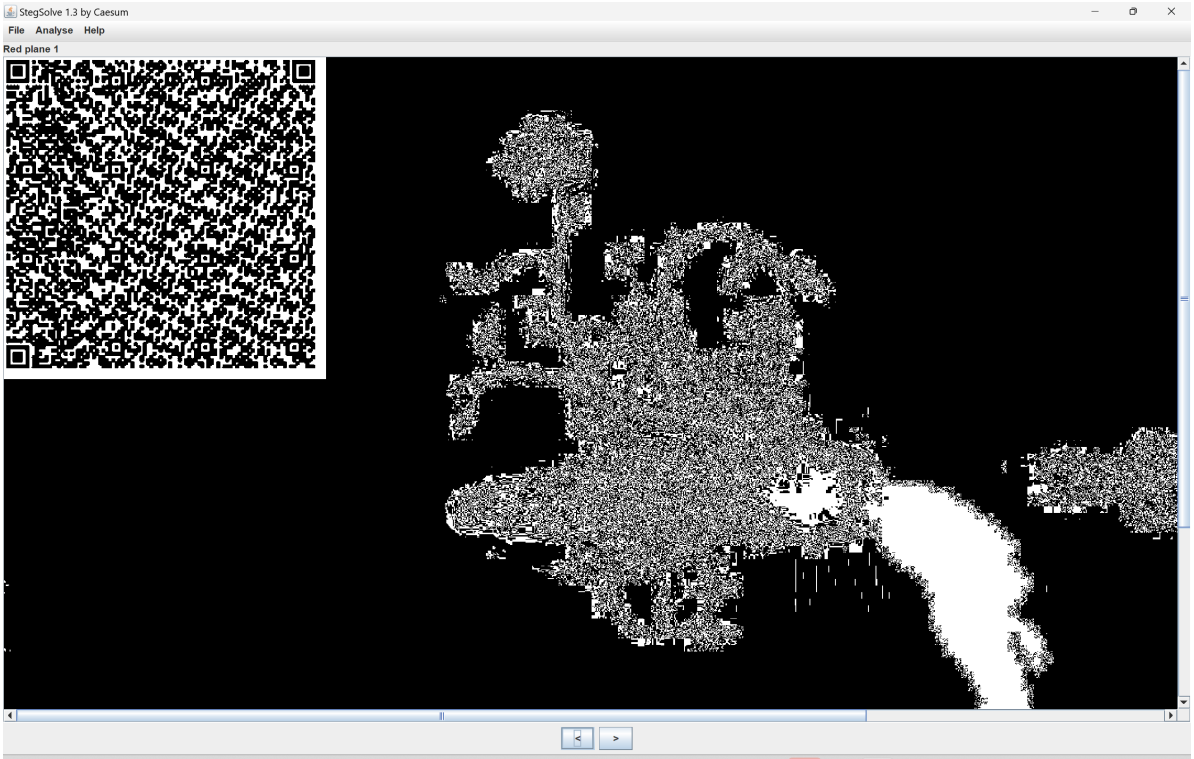
LSB即为最低有效位（Least Significant Bit，lsb），图片中的图像像素一般是由RGB三原色（红绿蓝）组成，每一种颜色占用8位，取值范围为0x00~0xFF，即有256种颜色，一共包含了256的3次方的颜色，即16777216种颜色。而人类的眼睛可以区分约1000万种不同的颜色，这就意味着人类的眼睛无法区分余下的颜色大约有6777216种。**LSB隐写就是修改RGB颜色分量的最低二进制位也就是最低有效位（LSB），而人类的眼睛不会注意到这前后的变化。**



工具：stegsolve

1 颜色通道

改变颜色通道尝试获得信息

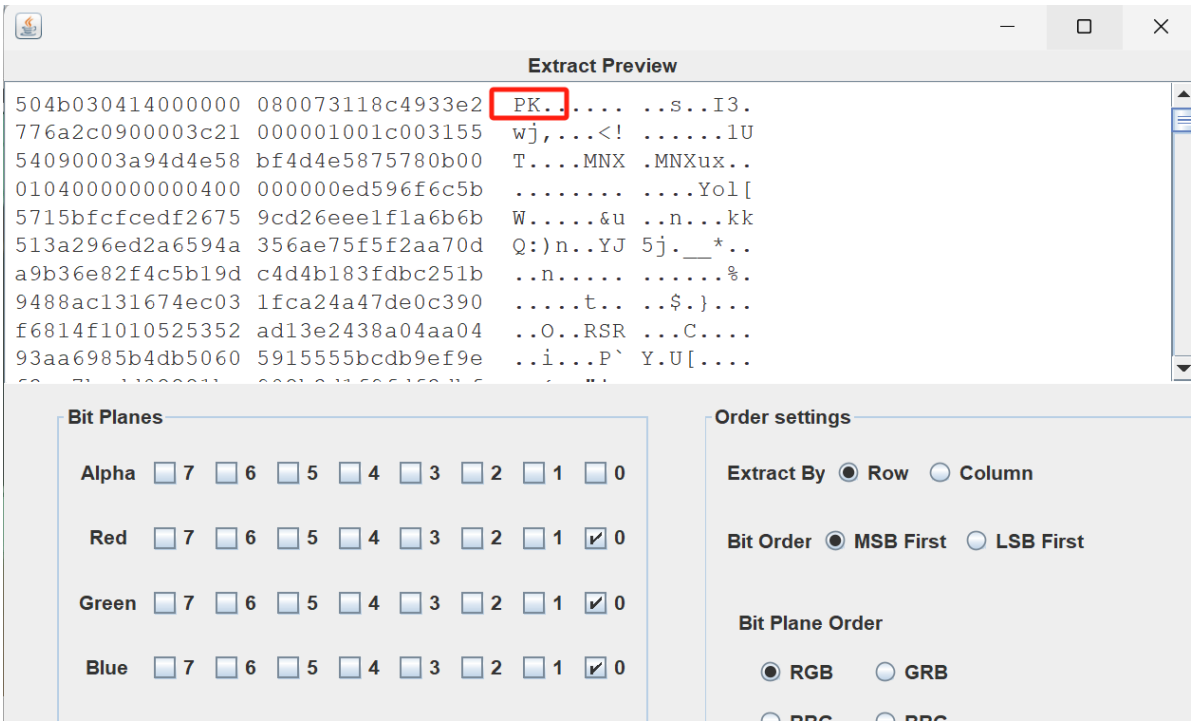


例题：攻防世界 - misc - 适合作为桌面

得到的二维码可以用QR_Research扫

2 数据提取

修改图片RGB颜色分量的最低二进制位



例题：攻防世界 - misc - misc_pic_again

这道题是隐藏了一个压缩包，还有可能遇到直接给出flag或者是提示的情况

3 Frame Browser 帧浏览器

可以查看动图的每一帧

例题：misc4.gif

4 Image Combiner

给出两张图片时可以尝试，导入图片的顺序会影响结果

例题：攻防世界 - misc - a_good_idea（用电脑自带的解压）

（四）Steghide

Steghide是一个隐写程序，可以将数据隐藏在各种图片文件以及音频文件之中。 支持类型：JPG、BMP、WAV 和 AU

下载：

```
sudo apt-get install steghide
```

用法：

```
加密：
steghide embed -cf [原图] -ef [要隐藏的文件] [-p 密码]

解密：
steghide info [文件名]      查看图片中嵌入的文件信息
steghide extract -sf [文件名] [-p 密码]
```

例题：ctfshow - misc - misc31 xiaomotuo.wav

三、音频隐写类

常见工具：**Audacity**, Adobe Audition, **SilentEye**, DeepSound, **MP3Stego**等。

先听音频是否有关键信息，比如摩斯电码（有间隔的长短电波）、SSTV（连续刺耳的电波）、拨号隐写等。也可以放进binwalk看是否有隐藏文件。

1 文件头

wav文件头：52494646E6AD250357415645666D7420

2 波形图

使用工具：Audacity/Adobe Audition

文件类型：wav

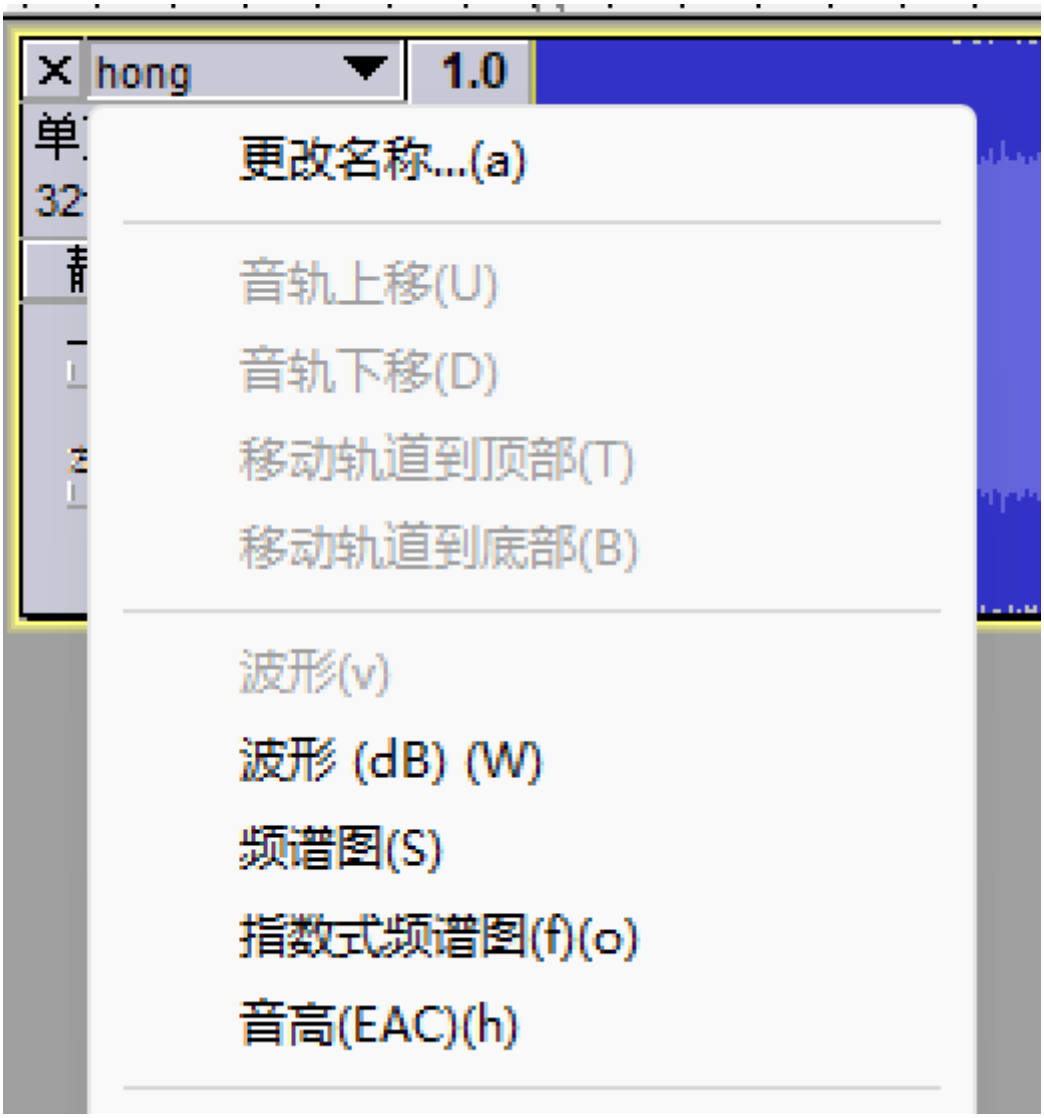
放大观察波形图，可能存在摩斯电码，或者根据波峰波谷转换01二进制

摩尔斯电码表					
字符	电码符号	字符	电码符号	字符	电码符号
A	• —	N	— •	1	• —————
B	— • • •	O	———	2	• • ———
C	— • — •	P	• —— •	3	• • • ——
D	— • •	Q	—— • —	4	• • • • —
E	•	R	• — •	5	• • • • •
F	• • — •	S	• • •	6	— • • • •
G	—— •	T	—	7	—— • • •
H	• • • •	U	• • —	8	——— • •
I	• •	V	• • • —	9	———— •
J	• ———	W	• ———	0	—————
K	— • —	X	— • • —	?	• • —— • •
L	• — • •	Y	— • • ——	/	— • • — •
M	——	Z	—— • •	( )	— • —— • —
				—	— • • • • —

3 频谱图

使用工具：Audacity

文件类型：wav



4 SilentEye/DeepSound

文件类型：wav

在音频文件里面，写入了其它的文件。

5 拨号隐写

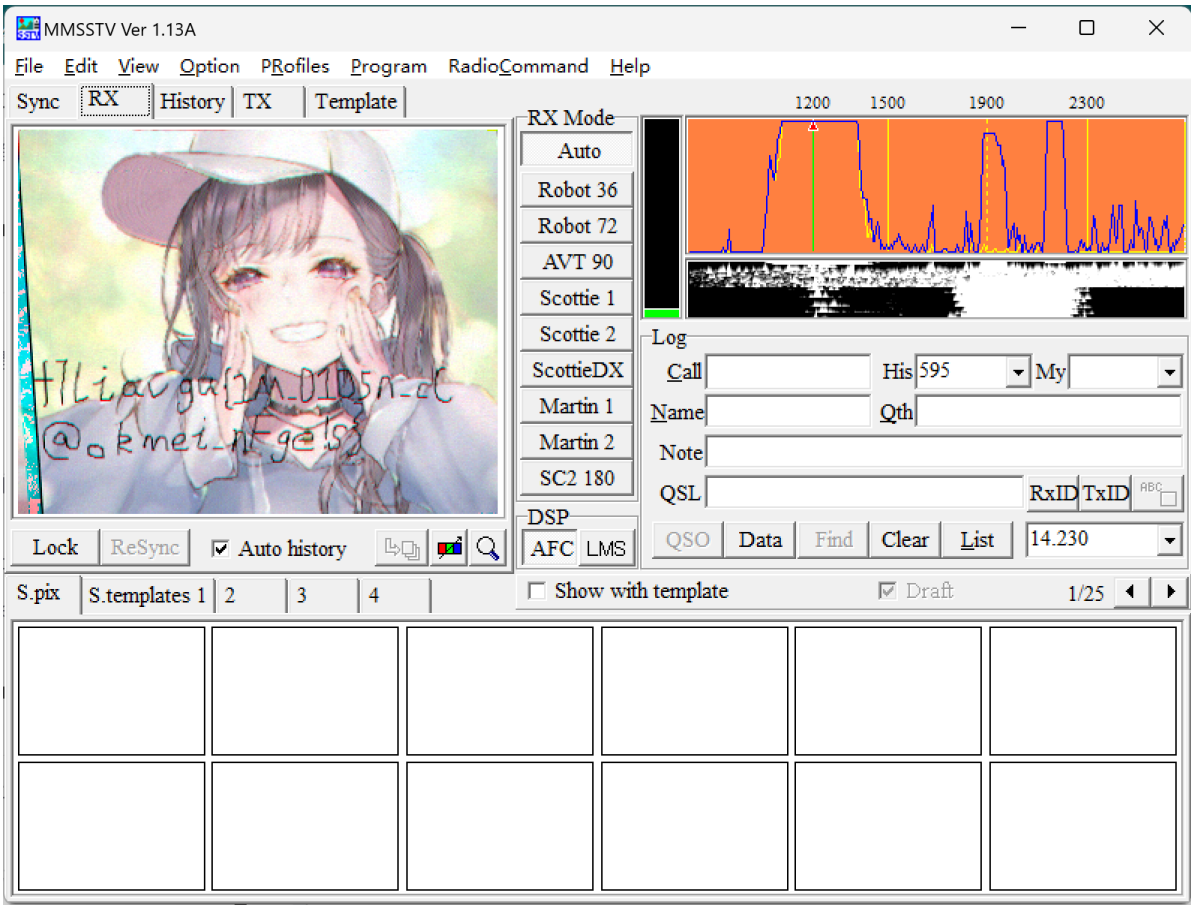
声音听起来像手机播号时的声音，常常混杂着其它音乐，需要用Audacity删除，留下拨号声音，再使用软件dtmf2num或人工来复原拨号的数字

6 SSTV

慢扫描电视（Slow-scan television 简称SSTV）是业余无线电爱好者的一种主要图片传输方法，慢扫描电视通过无线电传输和接收单色或彩色静态图片，其生成图片特别慢，可能需要几十秒甚至几分钟

特征：其声音听起来像刺耳的电波

工具：MMSSTV https://hamsoft.ca/pages/mmsstv.php



例题：攻防世界 - misc - 来自银河的信号

7 DIFF

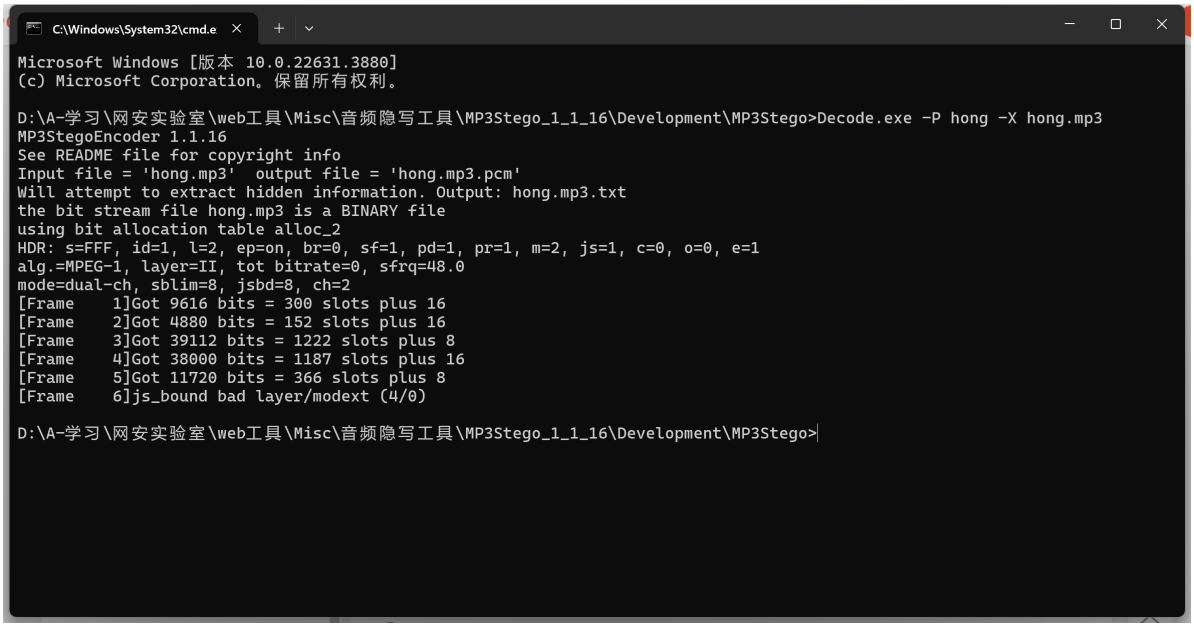
使用工具：Adobe Audition
文件类型：wav

使用反相将得到的音频文件与原曲Diff，或许就可以发现隐藏在其下面的隐藏音频，如摩斯电码，SSTV

8 MP3隐写

使用工具：mp3stego
文件类型：mp3

```
# 隐藏信息
# -E 读取隐藏信息文件的内容，-P 设置密码
encode.exe -E [要隐藏的文件] -P [密码] [原来的音频] [输出的mp3]
# 解密信息
decode.exe -X [mp3文件] -P [密码]
```



例题密码：n0_p4ssw0rd

四、压缩包类

（一）伪加密

1 zip伪加密

一个zip文件由三个部分组成：压缩源文件数据区+压缩源文件目录区+压缩源文件目录结束标志

压缩源文件数据区：

50 4B 03 04：头文件标记

14 00：解压文件所需pkware版本

00 00：全局方式位标记（有无加密）

压缩源文件目录区：

50 4B 01 02：目录中文件文件头标记

3F 00：压缩使用的pkware版本

14 00：解压文件所需pkware版本

00 00：全局方式位标记（有无加密，改为09 00就会提示有密码，只要是奇数就代表加密）

使用7zip等软件可以直接解压zip伪加密的文件。

2 rar伪加密

把第11个字节或第24个字节修改为1即可实现伪加密。

使用WinRAR等软件可以直接解压rar伪加密的文件。

（二）密码爆破

工具：ARCHPR

例题：攻防世界 - misc - János-the-Ripper

（三）压缩包修复

缺少文件头可以用WinRAR自动修复，也可以在Winhex中手动加入

还可以用WinRAR查看文件注释等内容

五、流量分析类

筛选和过滤无关的流量信息，根据关键流量信息找出flag或者相关线索，一般flag隐藏在某个数据包里，或者需要从中提取一个文件出来等等。（可以用binwalk查看是否能分离出文件）

例题：被嗅探的流量

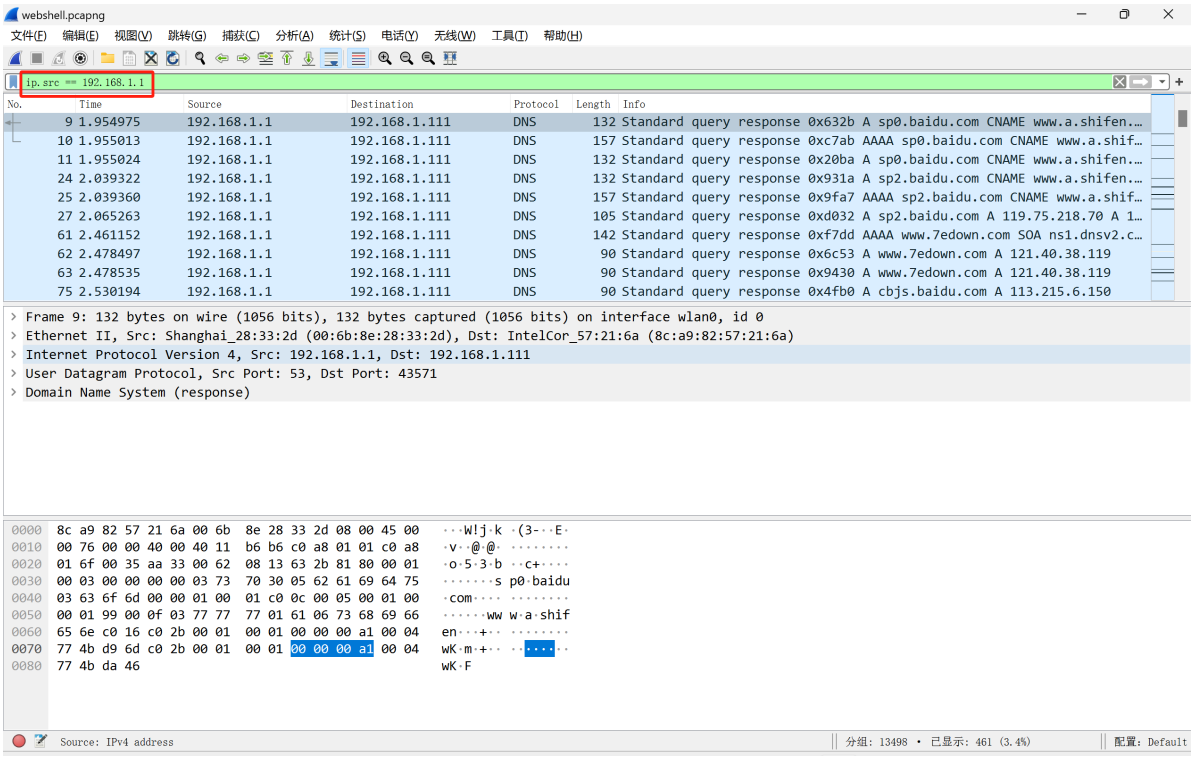
1 数据包筛选

筛选IP

源IP筛选

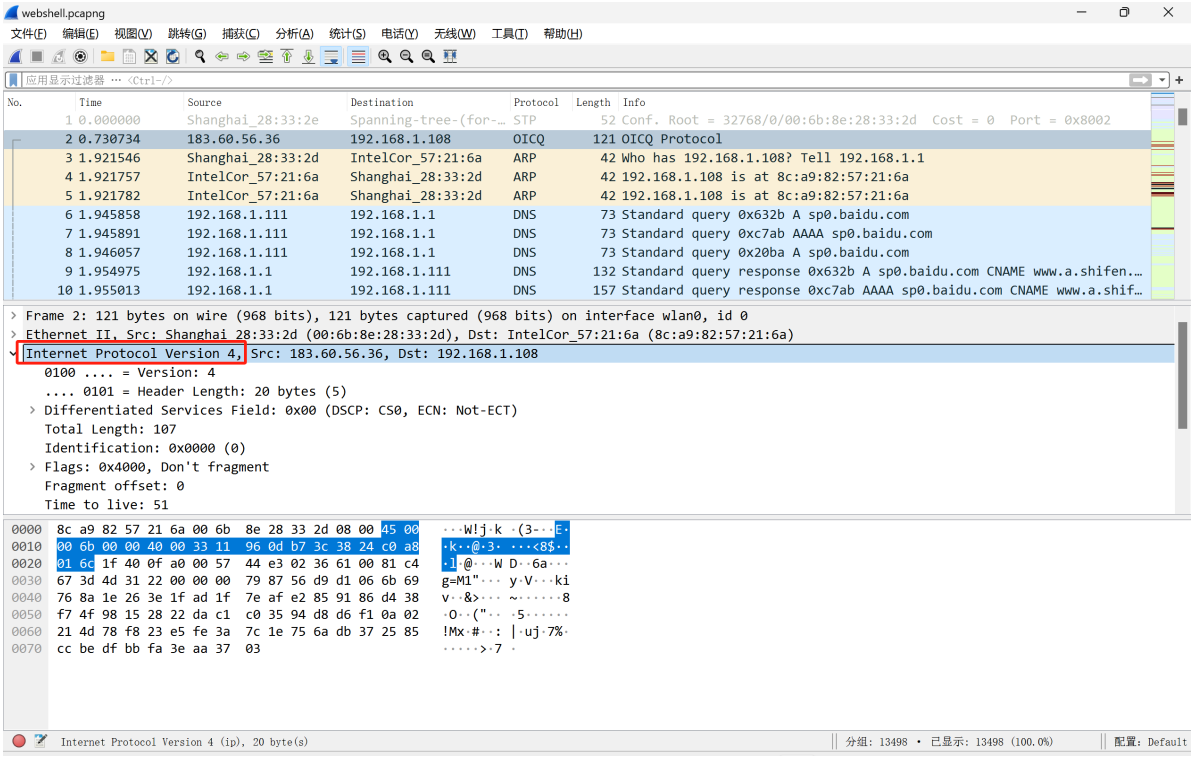
方法一

```
ip.src == 源ip地址
```

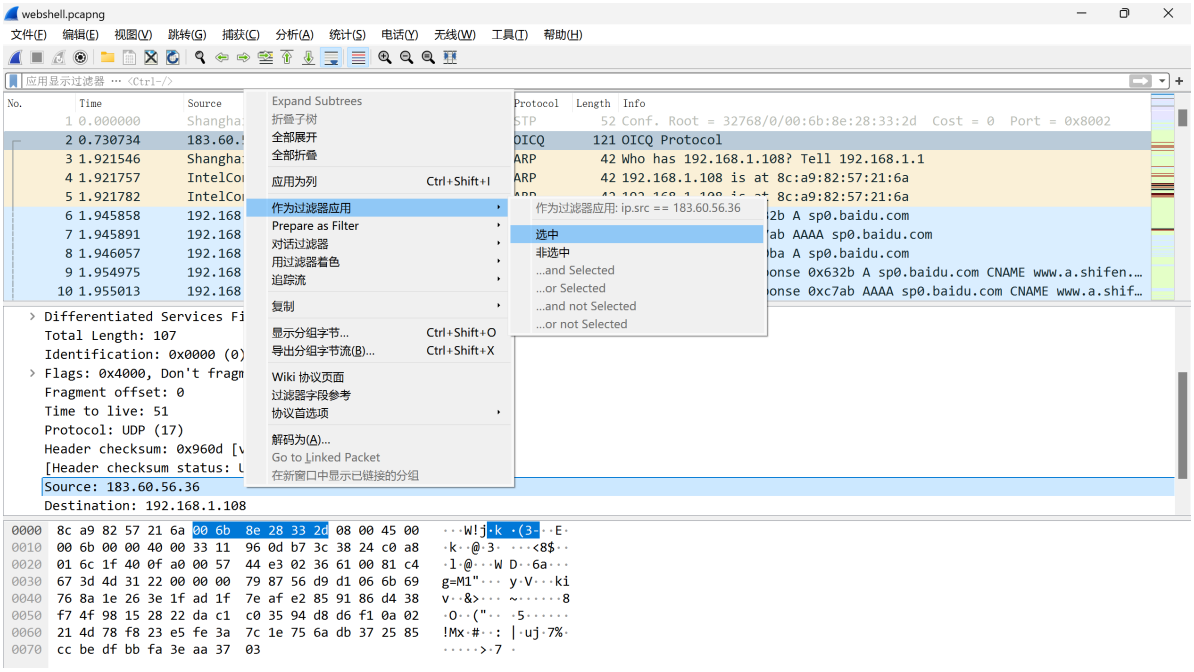


方法二

选中一个源IP是筛选条件的数据包，找到Internet Protocol Version 4下的Source字段



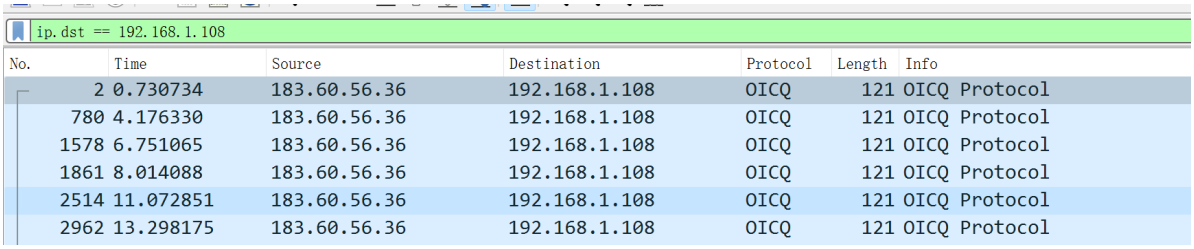
右击Source字段，再选择作为过滤器应用，最后点击选中，即可筛选出该源IP的所有包



目的IP筛选

方法一

```
ip.dst == 目的ip地址
```



ip.dst == 192.168.1.108

No.	Time	Source	Destination	Protocol	Length	Info
2	0.730734	183.60.56.36	192.168.1.108	OICQ	121	OICQ Protocol
780	4.176330	183.60.56.36	192.168.1.108	OICQ	121	OICQ Protocol
1578	6.751065	183.60.56.36	192.168.1.108	OICQ	121	OICQ Protocol
1861	8.014088	183.60.56.36	192.168.1.108	OICQ	121	OICQ Protocol
2514	11.072851	183.60.56.36	192.168.1.108	OICQ	121	OICQ Protocol
2962	13.298175	183.60.56.36	192.168.1.108	OICQ	121	OICQ Protocol

方法二

与源IP筛选方法类似，只是字段改为Destination

mac地址筛选

```
eth.dst ==A0:00:00:04:C5:84 筛选目标mac地址
eth.addr==A0:00:00:04:C5:84 筛选MAC地址
```

端口筛选

```
tcp.dstport == 80  筛选tcp协议的目标端口为80的流量包
tcp.srcport == 80  筛选tcp协议的源端口为80的流量包
udp.srcport == 80  筛选udp协议的源端口为80的流量包
```

协议筛选

```
tcp  筛选协议为tcp的流量包
udp 筛选协议为udp的流量包
arp/icmp/http/ftp/dns/ip 筛选协议为arp/icmp/http/ftp/dns/ip的流量包
```

包长度筛选

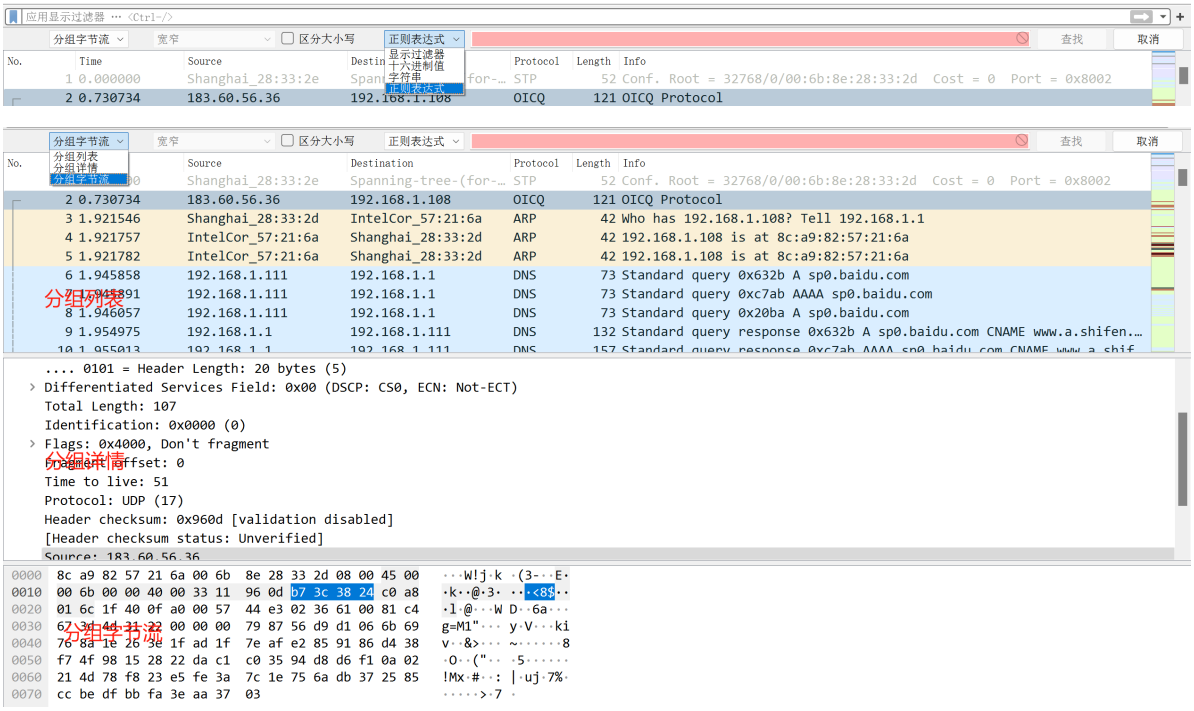
```
udp.length ==20   筛选长度为20的udp流量包
tcp.len >=20  筛选长度大于20的tcp流量包
ip.len ==20  筛选长度为20的IP流量包
frame.len ==20 筛选长度为20的整个流量包
```

http请求筛选

```
请求方法为GET：http.request.method==“GET”        筛选HTTP请求方法为GET的 流量包
请求方法为POST：http.request.method==“POST”       筛选HTTP请求方法为POST的流量包
指定URL：http.request.url==“/img/logo-edu.gif” 筛选HTTP请求的URL为/img/logo-edu.gif的流量包
请求或相应中包含特定内容：http contains “FLAG”    筛选HTTP内容为/FLAG的流量包
```

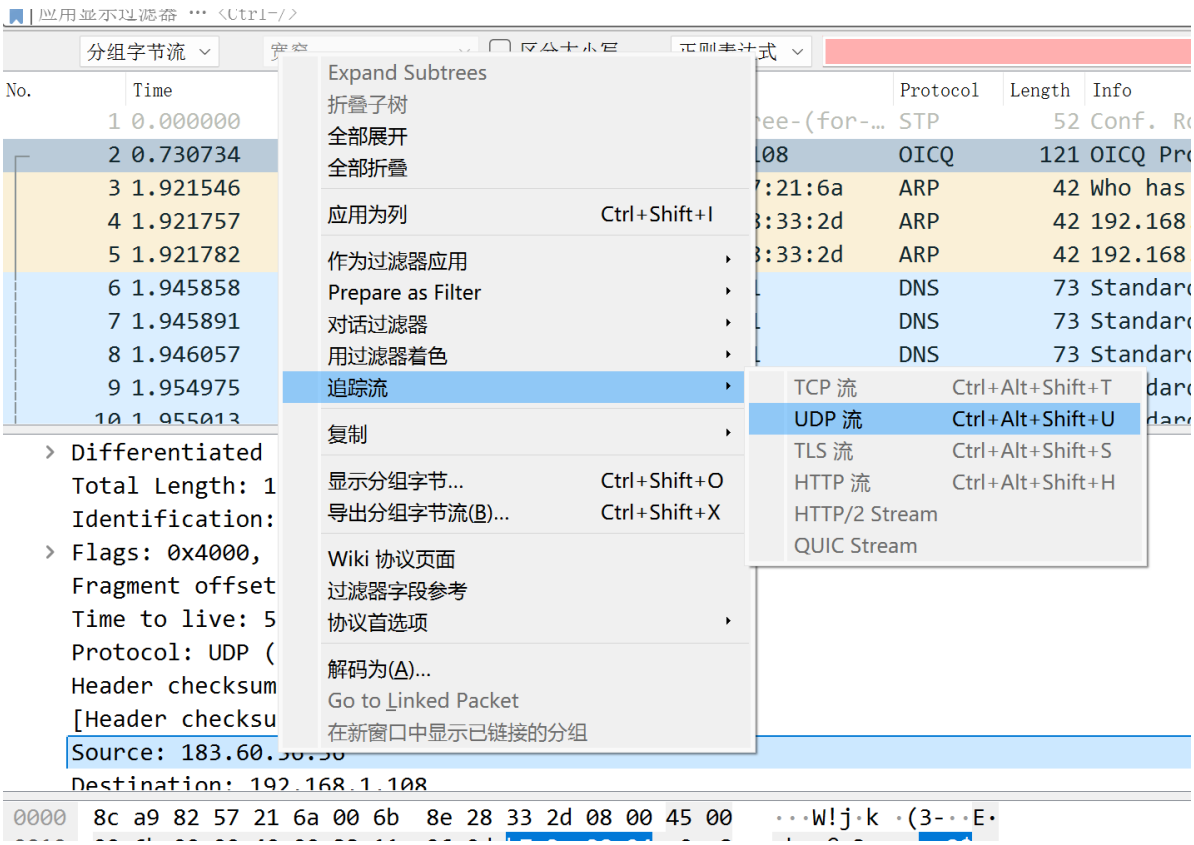
2 数据包搜索

通过Ctrl+F可以进行关键字搜索，支持正则表达式、字符串、十六进制等方式，分组列表、分组详情、分组字节流三个选项，分别对应界面的三个部分

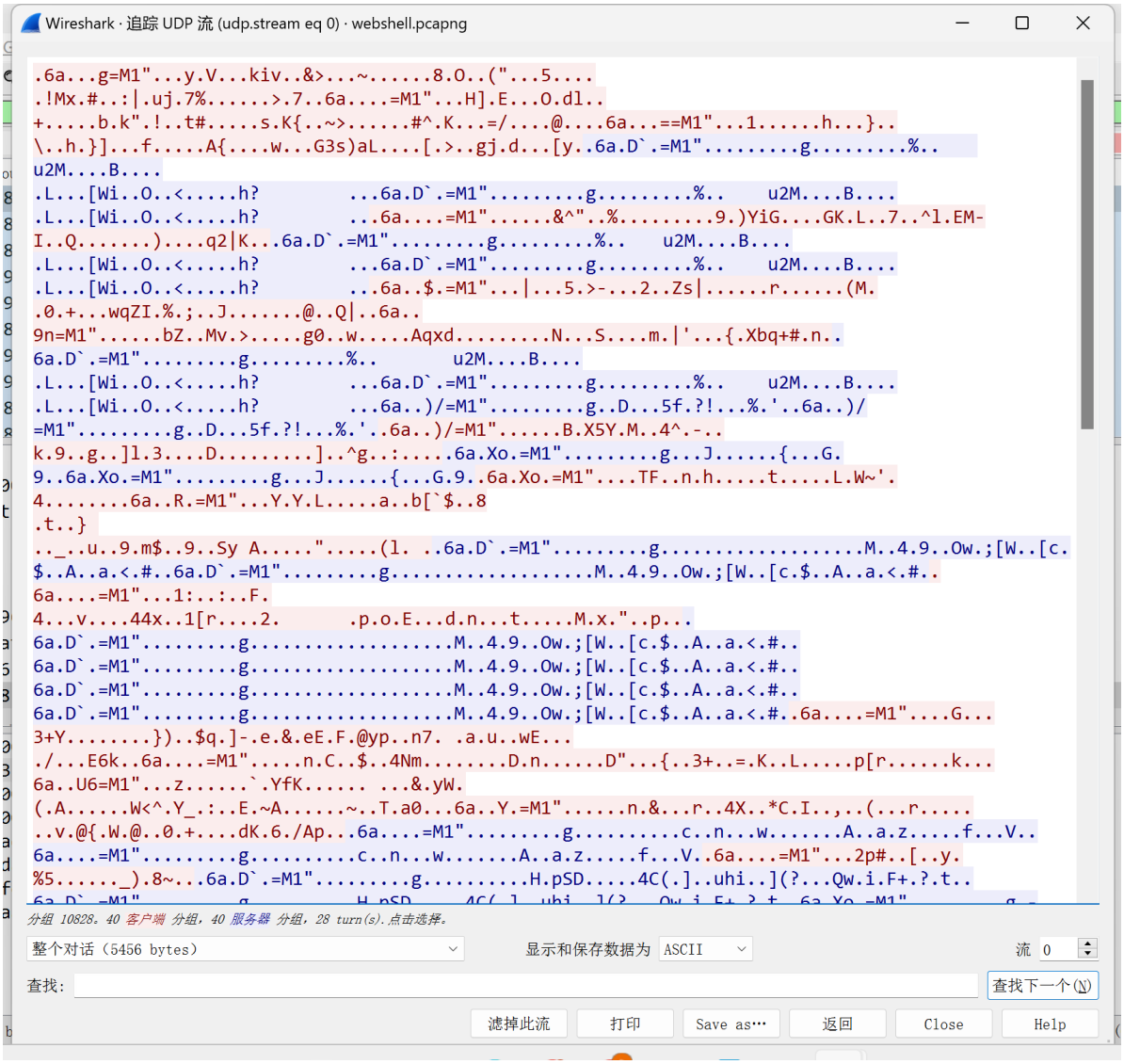


3 数据包还原

追踪流功能，可以将HTTP或TCP流量集合在一起并还原成原始数据：右击选中想要还原的流量包，选择追踪流 - TCP流/UDP流/SSL流/HTTP流



在弹出的窗口中可以看到被还原的流量信息

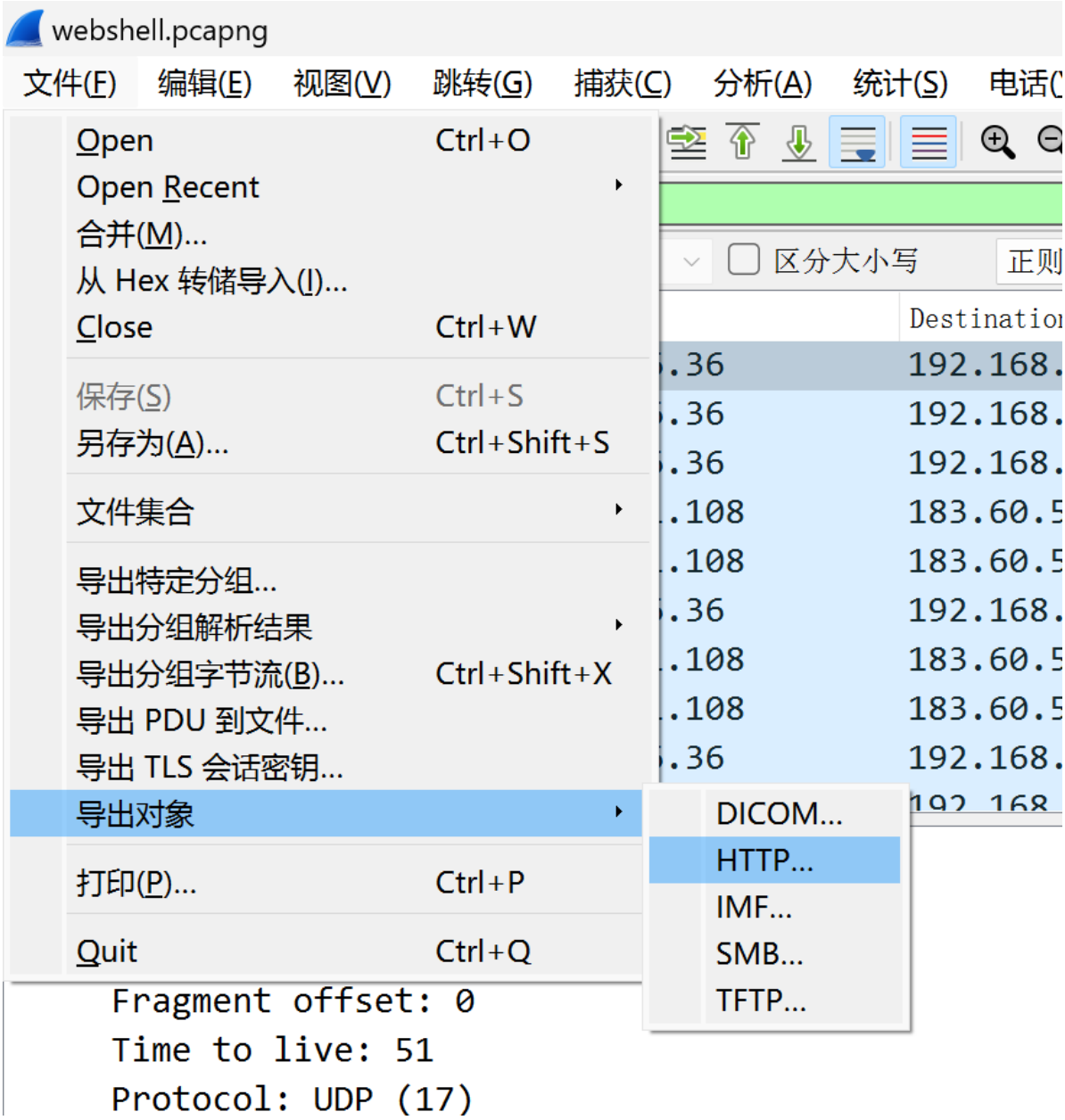


4 数据提取

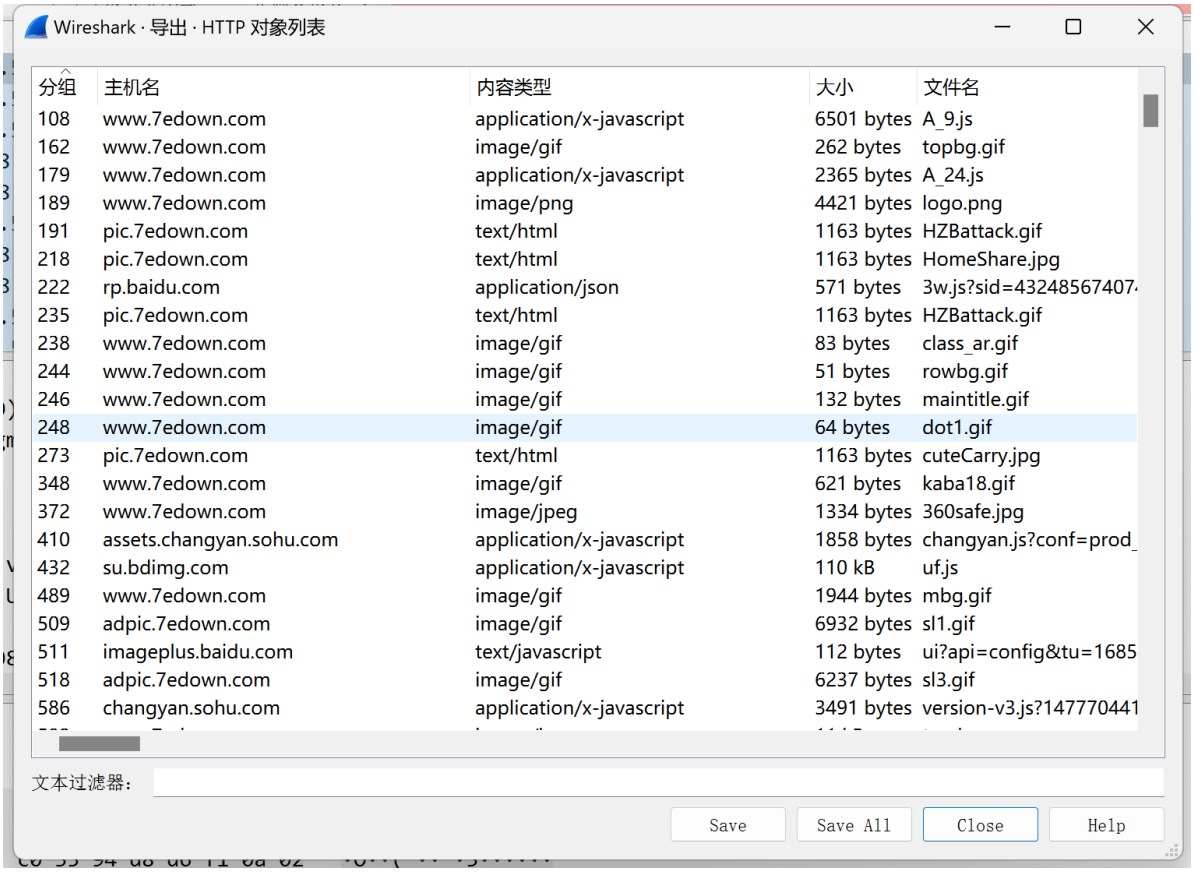
提取通过http传输（上传/下载）的文件内容

自动提取

文件->导出对象->HTTP



在打开的对象列表中找到有价值的文件，如压缩文件、文本文件、音频文件、图片等，点击Save进行保存，或者Save All保存所有对象再进入文件夹进行分析。



手动提取

选中http文件传输流量包，在分组详情中找到data，Line-based text， JPEG File Interchange Format,，data:text/html层，鼠标右键点击 – 选中 导出分组字节流。

如果是菜刀下载文件的流量，需要删除分组字节流前开头和结尾的X@Y字符，否则下载的文件会出错。鼠标右键点击 – 选中 显示分组字节。

在弹出的窗口中设置开始和结束的字节（原字节数开头加3，结尾减3）